ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA1405 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. **A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.**

Answer:

No, I would not exploit the vulnerability because the system is not included in the approved testing scope.

- Authorization: Ethical hackers must test only the systems explicitly authorized by the client.
- Scope limitation: A one-line email without a clear scope is insufficient for a safe engagement. I would request written clarification before continuing.
- Responsible disclosure: I would document the vulnerability using non-invasive methods, if permitted, and report it to the client.
- Avoiding harm: Exploiting the vulnerability could cause data loss, service disruption, or unauthorized access.
- Professional ethics: I would follow the principles of integrity, confidentiality, accountability, and responsible disclosure.

Conclusion: I would obtain written authorization and an updated scope before attempting to validate the vulnerability. Discovering a weakness does not automatically give permission to exploit it.

2. **You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?**

Answer:

I would avoid executing any SQL injection test that could expose, modify, or damage real customer financial data.

- Stop and assess: I would review the vulnerability and determine whether it can be validated safely.
- Use a safe environment: I would prefer a staging environment containing dummy or anonymized data.
- Minimize testing: If production testing is necessary and explicitly authorized, I would use the least intrusive proof of concept and avoid retrieving, changing, or deleting customer records.
- Protect confidentiality: I would not copy, download, or disclose sensitive financial information.
- Coordinate with the client: I would agree on monitoring, emergency contacts, rollback procedures, and stop conditions before testing.

Precautions before the engagement:

1. Obtain written authorization and clearly define the scope.
2. Identify sensitive systems and data.
3. Establish rules of engagement and permitted testing methods.
4. Arrange backups, recovery plans, and an emergency contact.
5. Define data-handling, confidentiality, and incident-reporting procedures.

Conclusion: The goal is to prove and report the vulnerability without compromising customer privacy, financial data, or business operations.

3. **During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.**

Answer:

I would take immediate responsibility for the outage and prioritize restoring the service safely.

Steps to prevent the incident

- Pre-test planning: I would identify production systems and assess their availability risks before testing.
- Safe testing: I would avoid aggressive scanning, excessive requests, and stress testing unless specifically authorized.
- Rate limiting: I would use conservative testing rates and monitor server performance.
- Monitoring: I would watch CPU usage, memory, response times, and error rates during testing.
- Emergency plan: I would establish a stop procedure and emergency contacts before starting.

Responsibilities after the outage

1. Stop the test immediately.
2. Notify the client and the designated emergency contact.
3. Assist the authorized IT team with recovery.
4. Preserve relevant logs and document the timeline.
5. Investigate the cause and prepare an incident report.
6. Recommend preventive measures to avoid recurrence.

Conclusion: Ethical hackers must minimize harm, act transparently, and accept responsibility for accidental damage. They should never hide an incident or continue testing while the production system is unavailable

4. **A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?**

Answer:

This request creates ethical, operational, and legal risks because the IT department may mistake authorized testing for a real cyberattack.

Risks involved

- Operational risk: Security controls may block the test or production services may be disrupted.
- Incident-response risk: The IT team may initiate an emergency response or shut down critical systems.
- Legal risk: Without clear written authorization, the tester may face allegations of unauthorized access.
- Trust risk: The exercise may create confusion between the client, security team, and other stakeholders.

How I would structure the engagement

1. Obtain written authorization from an executive or system owner with authority to approve the test.
2. Clearly define the targets, testing period, permitted techniques, and prohibited actions.
3. Agree on an emergency contact and a confidential escalation process.
4. Keep the designated test controller or independent security lead informed, even if frontline IT staff are not told.
5. Define immediate stop conditions for service disruption, data exposure, or safety concerns.
6. Conduct a debrief afterward to evaluate detection and response performance.

Conclusion: A surprise test can measure real-world detection capability, but it must be formally authorized, carefully controlled, and supported by an emergency response plan. Secrecy from the IT team must not mean secrecy from accountable management.

5. **You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.**

Answer:

A red team exercise and a vulnerability assessment both improve security, but they have different objectives, methods, and rules of engagement.

Real-world scenario: A bank wants to test its physical and digital security.

Aspect	**Red Team Exercise**	**Vulnerability Assessment**
Main objective	Test the bank's overall ability to detect and respond to attacks	Identify and classify security weaknesses
Approach	Simulates realistic attacker behavior	Scans and examines systems for vulnerabilities
Physical security	May test authorized entry controls and employee security awareness	Reviews access controls, locks, and physical security weaknesses
Digital security	Simulates approved attack paths to test defenses	Identifies outdated software, misconfigurations, and known vulnerabilities
Stealth	Usually attempts to avoid detection within agreed limits	Generally uses transparent, planned testing
Ethics	Must stay within strict authorization and safety limits	Must also follow authorization, privacy, and safety requirements
Deliverable	Attack-path findings, detection gaps, and response effectiveness	Vulnerability list, severity ratings, and remediation recommendations

Example of a red team exercise

- The bank authorizes a security team to test a branch's physical access controls and the security of its online banking environment.
- The team attempts approved physical entry simulations and controlled digital attack scenarios.
- The team evaluates whether security staff and monitoring systems detect the simulated activities.
- The team reports the attack path, detection failures, and recommendations for improving defenses.

Example of a vulnerability assessment

- The bank authorizes a security team to scan its servers, network devices, and online banking systems.
- The team identifies outdated software, weak configurations, and possible SQL injection vulnerabilities.
- Each vulnerability is documented and assigned a severity level.
- The bank receives a report with remediation steps and recommendations for retesting.

Rules of engagement for both approaches

1. Obtain written permission from the bank and relevant system owners.
2. Define the systems, physical locations, testing period, and permitted techniques.
3. Protect customer financial information and personal data.
4. Prohibit unauthorized fund transfers, destructive actions, and disruption of banking services.
5. Establish emergency contacts, stop conditions, and incident-reporting procedures.
6. Document all findings and provide a confidential report to the authorized stakeholders.

Conclusion: A red team exercise evaluates how effectively the bank detects and responds to realistic attacks, whereas a vulnerability assessment identifies and prioritizes security weaknesses. Both require explicit authorization, confidentiality, responsible testing, and measures to protect customers and banking operations.

Code of Conduct:

I ___K.GuruMahesh(192311343)_ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Rubrics

Criteria	**Weightage**	**Level 4 – Exemplary**	**Level 3 – Proficient**	**Level 2 – Developing**	**Level 1 – Beginning**
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand